

# Accesul securizat in retele corporative

## Introducere

*Securitatea retelelor de tip corporatie moderne a devenit o necesitate critica, fiind direct proportionala cu atentia pe care aceste infrastructuri o primesc din partea actorilor malitiosi. Acesti atacatori cauta sa exploateze vulnerabilitatile sistemelor din diverse motive precum, *castiguri financiare, spionaj corporativ, interese politico-militare sau chiar hacktivism* (actiuni motivate ideologic impotriva practicilor unei companii).*

Odata ce un atacator obtine accesul initial, de exemplu, prin *inginerie sociala (social engineering)* sau prin compromiterea fizica a unui dispozitiv folosind un *stick USB malitios* de tip **“Rubber Ducky”**, *acestia recurg adesea la tehnici avansate precum **Living on the Land (LotL)**. Aceasta tehnica presupune utilizarea instrumentelor native si legitime ale sistemului de operare (cum ar fi Powershell, Command Prompt sau Editorul de Registru) pentru a executa **comenzi malitioase**, permitand atacatorului sa se “ascunda la vedere” si sa evite solutiile clasice de securitate. Mai departe, compromiterea retelei se realizeaza prin tactici precum *escaladarea privilegiilor, miscare laterala*, iar in fazele finale, implementarea de atacuri de tip **Ransomware**.*

## Contextul Securitatii in Retelele Moderne

- **Evolutia perimetrului de retea**

Pentru a intelege complexitatea securizarii retelelor corporative, este necesara o analiza a evolutiei perimetrului de retea. Traditional, securitatea cibernetica se baza pe modelul **“Castel si Sant” (Castel and Moat)**, un

perimetru de rețea fix. Acest model pornea de la premisa ca amenințările provin exclusiv dintr-un mediu extern, iar tot ceea ce se afla în interiorul rețelei este implicit de încredere (cum este ilustrat în **Figura 1.1**). Aceasta abordare era eficientă în era în care rețele erau centralizate, izolate fizic, iar angajații lucrau dintr-un singur sediu fizic.

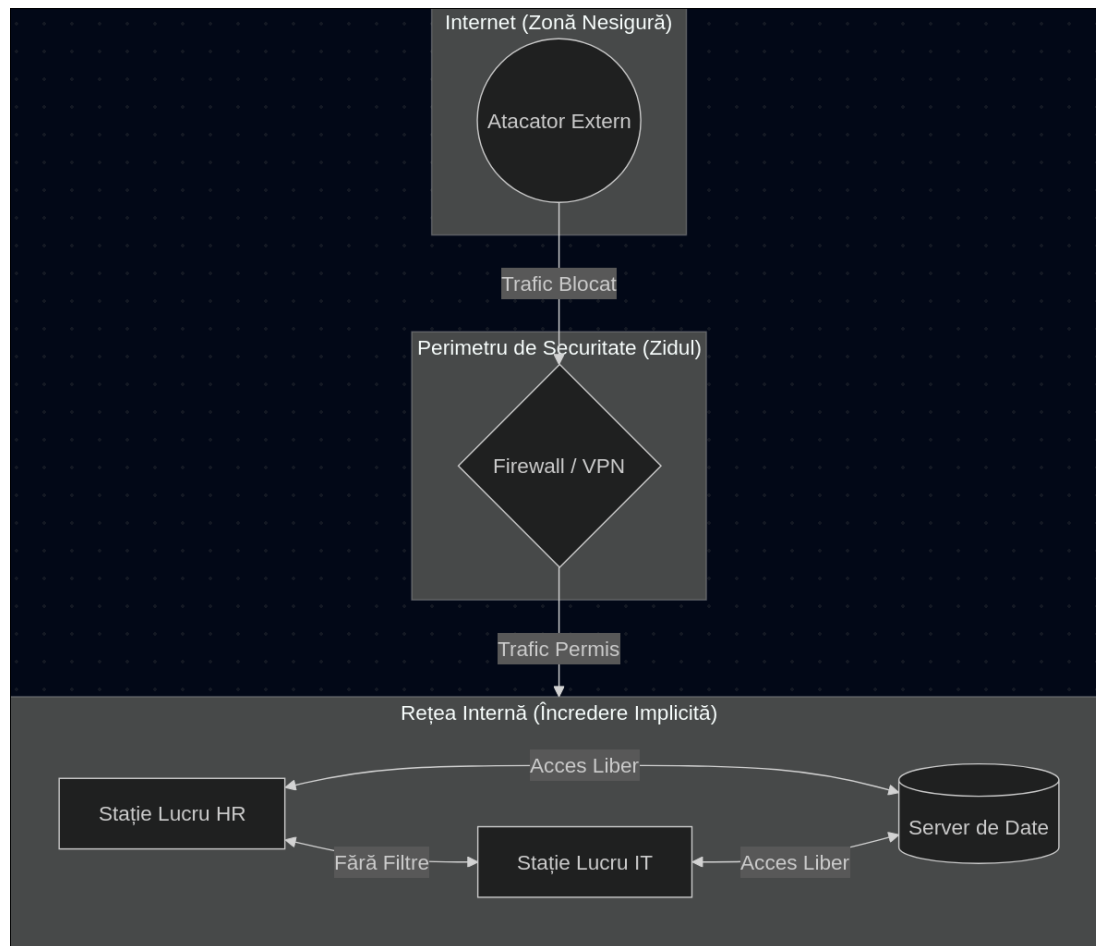


Figura 1.1 Arhitectura modelului Castel și Sant (Adaptat după Cloudflare)

Cu toate acestea, progresul tehnologic a dictat schimbări drastice. În prezent, rețele s-au descentralizat, prezentată în **Figura 1.3**, odată cu adoptarea tehnologiilor cloud, a infrastructurilor hibride, a muncii de la distanță (**Remote Desktop/VPN**) și a dispozitivelor mobile (**BYOD – Bring Your Own Device**). Odată cu dizolvarea perimetrului tradițional, organizațiile operează la nivel global, oferind utilizatorilor acces la resurse de oriunde și de

pe orice dispozitiv. Aceasta suprafata de atac extinsa ofera atacatorilor oportunitati multiple de a gasi si exploata vulnerabilitati.

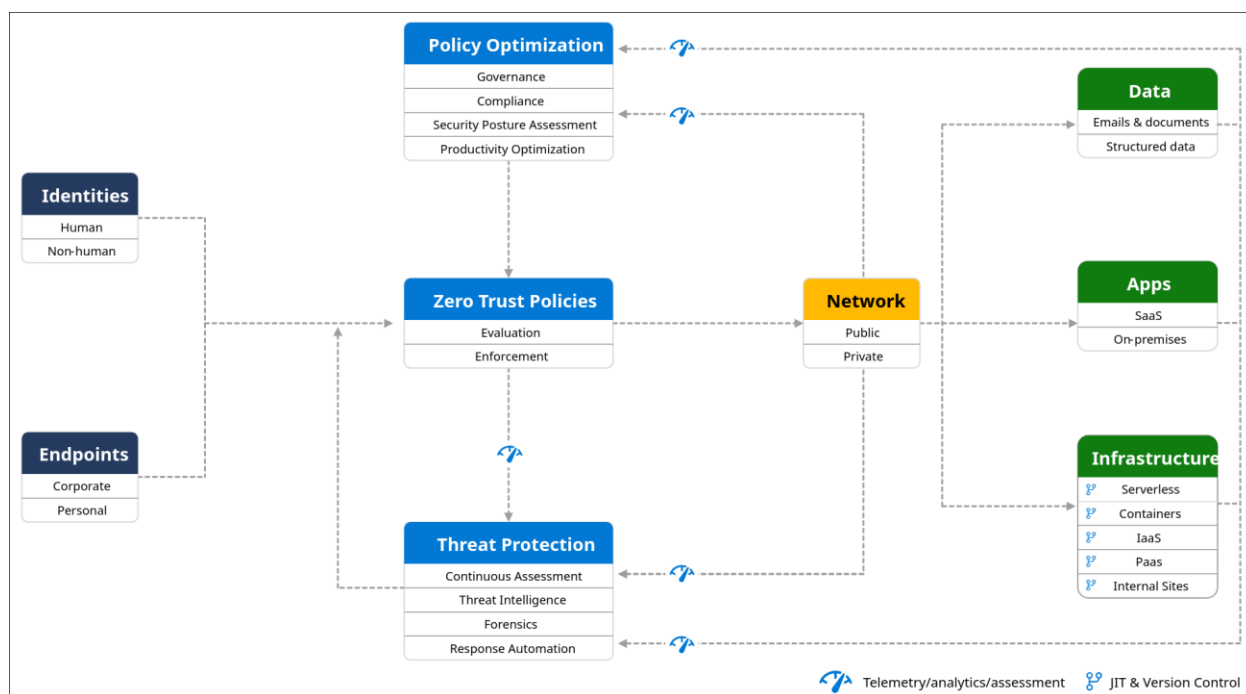


Figura 1.2 Arhitectura modelului Zero Trust (Microsoft)

- **Amenințări specifice mediului corporate**

Intr-un mediu descentralizat, în care atacatorii reușesc adesea să depășească barierele externe de securitate, tacticile acestora s-au adaptat pentru a maximiza impactul. Cele mai critice amenințări interne includ:

- **Miscarea Laterală (Lateral Movement):**

Dupa ce compromite o stație de lucru obișnuită (de exemplu aparținând unui angajat de la HR), un atacator nu se oprește acolo. Folosind credențialele furate din memoria sistemului, acesta *navighează din computer în computer (lateral)* în căutarea unor conturi cu **drepturi superioare**, până când atinge serverele critice. Acest proces de navigare este reprezentat în **Figura 1.3**.

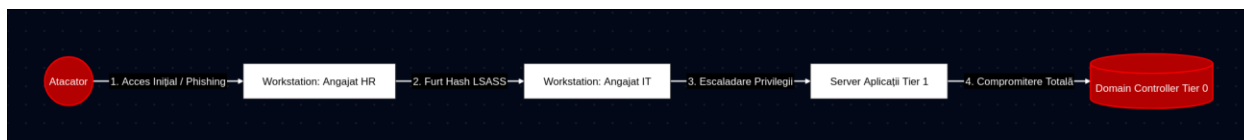


Figura 1.3 Diagrama explicativa miscare laterala (Adaptat dupa Microsoft, Defender for Identity)

- **Escaladarea Privilegiilor (Privilege Escalation):**

Reprezinta procesul prin care un atacator, avand acces la un cont cu *drepturi standard*, **exploateaza** o eroare de configurare, o vulnerabilitate a sistemului de operare sau o politica de acces permisiva (cum ar fi *permisiunile de Active Directory* gestionate incorect) pentru a obtine drepturi de **Administrator**.

- **Ransomware si Extorcarea Datelor:**

Obiectivul final al multor atacuri moderne este **criptarea infrastructurii** si *blocarea accesului organizatiei la propriile date*. In contextul actual, atacurile **ransomware** implica adesea si o componenta de *dubla-extorcere*, atacatorii amenintand cu publicarea datelor confidentiale daca nu este platita rescumpararea.

- **Identitatea ca nou perimetru de securitate**

Dizolvarea conceptului de “*retea interna sigura*” a creat un vid in arhitectura de securitate. Daca o organizatie nu mai poate avea incredere in reseaua de pe care se conecteaza un utilizator, mecanismul de validare trebuie sa se mute la nivelul **Identitatii**.

Astfel, *managementul identitatii si al accesului (IAM – Identity Access Management)* a devenit esenta securitatii moderne. Identitatea actioneaza ca noul perimtru logic: *autentificarea si autorizarea nu se mai fac pe baza adresei IP, ci pe baza dovezii matematicii (cum ar fi tichetele Kerberos din Active Directory)* care confirma cine este utilizator si la ce date are acces in

*mod legitim. Acest nivel de granularitate face tranzitia necesara catre paradigma “Zero Trust” si spre o arhitectura bazata pe **Controlul Accesului pe Baza de Roluri (RBAC)**. Intr-un astfel de sistem, chiar daca o identitate este compromisa, implementarea stricta a “**privilegiului minim**” asigura izolarea incidentului si previne compromiterea intregii infrastructuri corporative.*

## **Active Directory Domain Services (AD DS) - Arhitectura si Vulnerabilitati**

- **Componentele AD**

***Active Directory (AD DS)** este un serviciu de director (*directory service*) dezvoltat de **Microsoft**, fundamentat pe o arhitectura ierarhica logica, al carui rol principal este stocarea, organizarea si securizarea informatiilor despre entitatile dintr-o retea corporativa. Acesta ofera metode standardizate de interogare si stocare a informatiilor, facandu-le disponibile in mod eficient si securizat atat pentru administratori, cat si pentru utilizatorii finali.*

*Baza functionarii **AD DS** este o baza de date structurata ierarhic. Datele stocate reprezinta obiecte (**AD DS objects**), care modeleaza elemente si resurse distribuite in lumea reala: conturi de utilizatori, statii de lucru, servere, volume de date partajate si imprimante de retea.*

*Securitatea este profund integrata in **AD DS** prin *mecanisme de autentificare robusta si control granular al accesului la obiecte*. Unul dintre cele mai mari avantaje ale acestei arhitecturi este implementarea conceptului de **Single Sign-On (SSO)**. Prin utilizarea unui *singur set de credentiale (nume de utilizator si parola)*, utilizatorii autorizati pot accesa resurse partajate de oriunde din retea. Simultan, administratorii pot gestiona intreaga organizatie dintr-un *punct central*. Administrarea bazata pe **politici centralizate (Policy-Based Management)** standardizeaza securitatea si simplifica gestionarea*

chiar si a celor mai complexe retele globale. Pentru a structura eficient informatia, arhitectura logica a Active Directory se bazeaza pe patru componente fundamentale: Paduri (Forests), Domenii (Domain), Unitati Organizationale (OU) si Obiecte.

- **Padurile (Forests):** Reprezinta cel mai inalt nivel de organizare logica in *Active Directory*. O padure este o colectie de unul sau mai multe domenii care partajeaza o schema comuna, precum **structura bazei de date** si un catalog global, precum **indexul de cautare**. Fundamental pentru securitate, padurea reprezinta adevarata granita de securitate (*security boundary*) a unei organizatii. In mod implicit, niciun utilizator dintr-o padure nu are acces la resursele din alta padure, cu exceptia cazului in care se stabilesc explicit relatii de incredere (*Trust Relationships*).
- **Domeniile (Domains):** Un domeniu este un grup logic de *obiecte si unitati organizationale* care impart aceeasi baza de date *Active Directory* si aceleasi politici de securitate. Domeniul actioneaza ca o **granita de administrare (administrative boundary)**. Autentificarea utilizatorilor si deciziile de autorizare sunt procesate de servere specializate din cadrul domeniului, cunoscute sub numele de **Controlere de Domeniu (Domain Controllers – DC)**.
- **Unitatile Organizationale (Organizational Units –OU):** Sunt containere logice in interiorul unui domeniu, folosite pentru a grupa *obiectele*. Acestea permit ierarhizarea resurselor pentru a reflecta structura administrativa sau departamentala a companiei. Totodata, acestea reprezinta nivelul de baza la care se pot delega permisiuni de administrare si la care se aplica *Politicile de Grup*.

- **Obiectele (Objects):** Reprezinta unitatea de baza a serviciului de director. Un obiect este o entitate distincta, descrisa printr-un set de attribute. De exemplu, un obiect de tip “Utilizator” va contine attribute precum nume, prenume, departament si adresa de email. Orice resursa din retea este reprezentata printr-un obiect.

- **Protocoale de autentificare: Kerberos vs. NTLM**

Intr-un mediu Active Directory, validarea identitatii utilizatorilor si a statiilor de lucru nu se realizeaza prin transmiterea parolelor clar prin retea, deoarece acest lucru ar compromite grav securitatea. In schimb, AD DS utilizeaza protocoale de autentificare criptografice, cele mai cunoscute fiind **NTLM (New Technology LAN Manager)** si **Kerberos**. Evolutia si diferentele dintre aceste doua protocoale explica multe dintre vulnerabilitatile exploatare in prezent de atacatori.

- **NTLM (Arhitectura Legacy si Vulnerabilitati):** NTLM este un protocol mai vechi, bazat pe un mecanism de tip **Challenge-Response (Provocare-Raspuns)**. Desi este mentinut din motive de compatibilitate pentru aplicatiile vechi, NTLM prezinta defecte arhitecturale majore. Cea mai mare problema este ca NTLM se bazeaza pe reprezentari **criptografice** ale parolelor, numite **hash-uri**, care raman stocate in memoria statiilor de lucru (in procesul **LSASS – Local Security Authority Subsystem Service**) pe durata sesiunii utilizatorului. Daca un atacator obtine drepturi de administrator pe o statie, poate extrage aceste hash-uri din memorie si le poate refolosi pentru a se autentifica pe alte

sisteme, tehnica cunoscuta sub numele de **Pass-the-Hash (PtH)**.

- **Kerberos (Standardul Modern):** Incepand cu Windows 2000, Kerberos versiunea 5 a devenit protocolul de autentificare implicit si recomandat pentru Active Directory. Spre deosebire de NTLM, Kerberos foloseste un sistem bazat pe o terta de incredere (***Trusted Third Party***), reprezentat de *Controlerul de Domeniu*, care actioneaza ca un *Centru de Distribuie a cheilor* (***Key Distribution Center – KDC***). Fluxul complex de schimb de tichete intre entitatile implicate este redat in **Figura 2.1**.



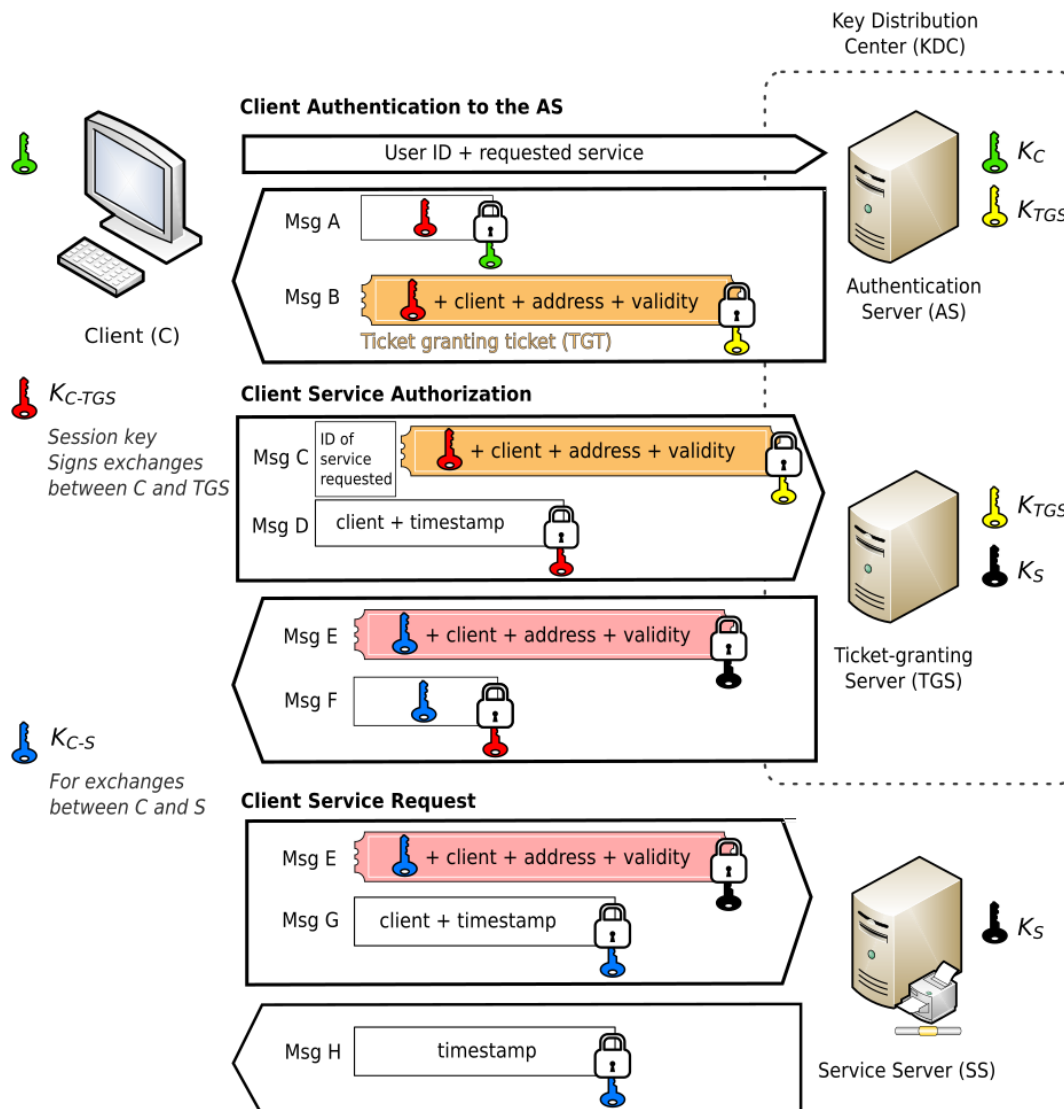


Figura 2.1 Fluxul de autentificare Kerberos (Sursa Wikipedia)

In loc sa foloseasca hash-uri refolosibile, Kerberos utilizeaza un sistem de **tichete** limitate de timp. Dupa o autentificare initiala reusita, utilizatorul primeste un tichet de acordare a tichetelor (**Ticket Granting Ticket– TGT**). Ulterior, cand utilizatorul doreste sa acceseze o resursa, prezinta *TGT-ul* catre *KDC* si primeste un tichet specific pentru acel serviciu (**Ticket Granting Service – TGS**). Deoarece Kerberos include marcaje de timp (**timestamps**) si sunt criptate simetric, acestea sunt mult mai rezistente la interceptare si la atacuri de tip *Replay*.

Totusi, chiar si cu protocolul Kerberos, credentialele cu privilegii ridicate pot fi compromise daca administratorii se autentifica pe statii de lucru nesigure. Aceasta realitate tehnica fundamenteaza necesitatea implementarii unor politici stricte de izolare administrativa.

- **Group Policy Objects (GPO) si managementul politicilor**

Daca Active Directory reprezinta structura organizatiei, **Politicile de Grup (Group Policy)** reprezinta motorul de aplicare a securitatii si de standardizare a mediului. Un **Obiect** de tipul **Politica de Grup (GPO)** este o colectie virtuala de setari de configurare a sistemului, permisiuni de securitate, scripturi de pornire si restrictii software.

GPO-urile isi demonstreaza utilitatea doar atunci cand sunt asociate (**linked**) unui nivel ierarhic din Active Directory, cum ar fi un **Domeniu** sau o **Unitate Organizationala (OU)**. Odata asociata, politica se aplica automat in mod descendent (*top-down*) tuturor utilizatorilor si computerelor din acel container logic. De exemplu, un GPO asociat cu OU a departamentului de Management va afecta exclusiv calculatoarele si conturile din acel departament.

In arhitecturile moderne de securitate, GPO-urile reprezinta instrumentul principal pentru reducerea suprafetei de atac (**System Hardening**). Prin intermediul lor, administratorii pot impune cerinte de complexitate a parolelor, pot bloca utilizarea dispozitivelor de stocare USB, pot configura auditarea avansata a proceselor pentru a genera log-uri detaliate si pot implementa reguli de restrictie software (**Software Restriction Policies** sau **AppLocker**).

Mai mult, Politicile de Grup permit controlul granular asupra drepturilor de conectare (**User Rights Assignments**). Acesta este mecanismul tehnic utilizat in arhitecturile de tip *Zero Trust* pentru a prevenii explicit *miscarea laterala*.

## Concepte de Securitate Avansata si Zero Trust

Vulnerabilitatile inerente protocoalelor de autentificare clasice, alaturi de descentralizarea retelelor corporative, au demonstrat ca securitatea bazata exclusiv pe apararea perimetrala este insuficienta. Pentru a contracara miscarea laterala si furtul de credentiale, organizatiile moderne trebuie sa adopte o schimbare fundamentala de paradigma. Aceasta tranzitie implica trecerea de la increderea implicita la verificarea matematica a identitatii, arhitectura definita prin conceptul **Zero Trust** si segregarea stricta a privilegiilor administrative prin modele de nivelare (**Tiering**).

### • Arhitectura Zero Trust si Principiul Privilegiului Minim

Modelul Zero Trust reprezinta o evolutie critica in securitatea cibernetica, fundamentata pe principiul *“nu avea incredere niciodata, verifica intotdeauna”*. Conform standardului **NIST Special Publication 800-207**, o arhitectura Zero Trust elimina conceptul de incredere bazata pe locatie in retea. Componentele fundamentale ale aceste arhitecturi sunt definite in **Figura 3.1**. Intr-o infrastructura traditionala, un dispozitiv conectat la reseaua interna a companiei primea automat un nivel de incredere ridicat. In paradigma Zero Trust, sistemul opereaza sub premisa compromiterii (**“assume breach”**), tratand fiecare solicitare de acces ca si cum ar proveni dintr-o retea externa ostila, indiferent de originea sa fizica sau logica.

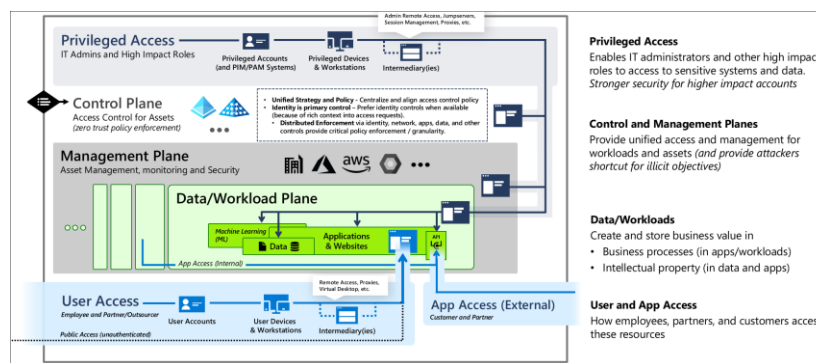


Figura 3.1 Arhitectura modelului Zero Trust (Sursa NIST Special Publication 800-207)

Implementarea cu succes a acestui model se bazează pe aplicarea riguroasă a **Principiului Privilegiului Minim (Principle of Least Privilege)**. Acest principiu stipulează ca unui utilizator sau unui proces trebuie să i se acorde exclusiv permisiunile necesare pentru a-și îndeplini sarcinile de serviciu, și doar pentru perioada de timp în care acele sarcini sunt executate. În contextul Active Directory, acest lucru înseamnă că drepturile de administrare nu mai sunt acordate permanent și global. Reducerea nivelului de acces diminuează drastic suprafața de atac, dacă un cont este compromis printr-un atac de tip “**phishing**”, daunele pe care atacatorul le poate produce sunt limitate strict la resursele la care acel utilizator specific avea acces.

- **Modelul de administrare pe niveluri (Tiering Model)**

Pentru a proteja identitățile cu privilegii ridicate împotriva extragerii de hash-uri din memorie, Microsoft a dezvoltat Modelul de Acces pentru Întreprinderi (**Enterprise Access Model**), cunoscut anterior ca Modelul de Tiering. Această arhitectură logică împarte resursele și conturile din Active Directory în trei straturi izolate, cu scopul de a preveni escaladarea privilegiilor și compromiterea totală a domeniului. Structura este concepută pentru a recunoaște faptul că nu toate activele tehnologice au aceeași valoare sau același grad de expunere la risc. Organizarea ierarhică a acestor straturi de încredere poate fi vizualizată în **Figura 3.2**.

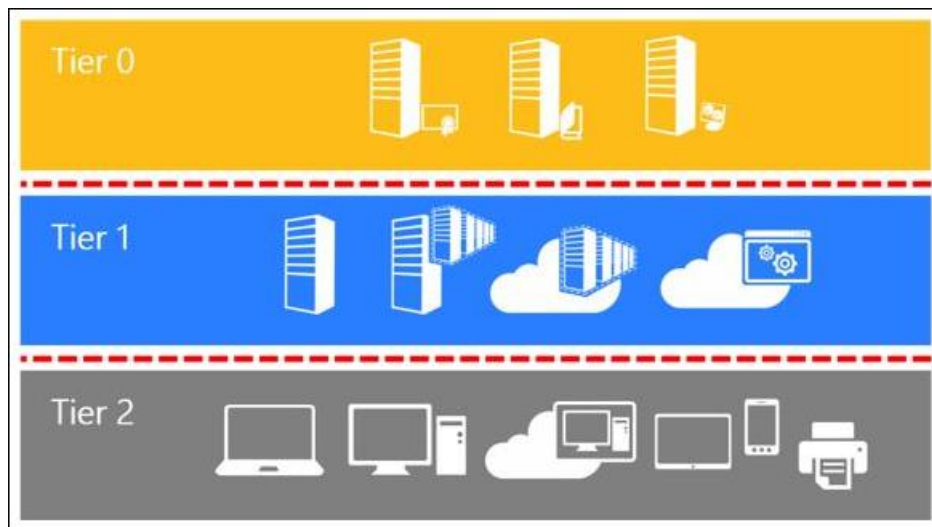


Figura 3.2 Arhitectura modelului de administratie pe niveluri (Sursa Microsoft, Enterprise Access Model)

Nivelul 0 (Tier 0) reprezinta planul de control al identitatii si radacina increderii pentru intreaga organizatie. Acest strat include *Controlerele de Domeniu, infrastructura cu chei publice (PKI)* si conturile de tip *Domain Admins*. Deoarece compromiterea acestui nivel inseamna preluarea controlului total asupra companiei, activele din Tier 0 necesita cel mai inalt grad de securitate si izolare.

Nivelul 1 (Tier 1) curpinde planul de **management de date**, incluzand *serverele de aplicatii, bazele de date si serviciile cloud* care sustin operatiunile de afaceri. Nivelul 2 (Tier 2) reprezinta planul *utilizatorilor*, format din *statiile de lucru obisnuite, laptopurile angajatilor si dispozitivele mobile*. Deoarece utilizatori din Tier 2 interactioneaza cu e-mailul si navigheaza pe internet, acest strat prezinta cel mai mare **risc de infectare cu malware** si reprezinta **punctul principal de intrare** pentru atacatori.

Regula fundamentala a acestui model este interzicerea stricta a suprapunerii credentialelor intre niveluri. Din punct de vedere tehnic si matematic, unui administrator din Tier 0 ii este complet intersis sa se autentifice pe un echipament de Tier 1 sau Tier 2. Aceasta restrictie, impusa de obicei prin **GPO-uri**, garanteaza ca hash-urile sau tichetele Kerberos ale conturilor cu privilegii maxime nu vor ajunge niciodata in memoria unei statii de lucru expuse riscului. Astfel, lantul miscarii laterale este rupt chiar inainte de a incepe.

- **Controlul Accesului pe Baza de Roluri (Role-Based Access Control – RBAC)**

Aceasta este metoda principala prin care organizatiile aliniaza permisiunile tehnice din Active Directory cu structura organizationala a afacerii. Spre deosebire de modelele mai vechi in care permisiunile de acces la fisiere sau aplicatii erau acordate direct si individual fiecarui cont de utilizator, modelul RBAC decupleaza indentitatea de permisiune. Mecanismul

de atribuire a permisiunilor bazat pe roluri este exemplificat in **Figura 3.3**. Accesul la resurse este dictat exclusiv de functia pe care persoana o indeplineste in cadrul organizatiei.

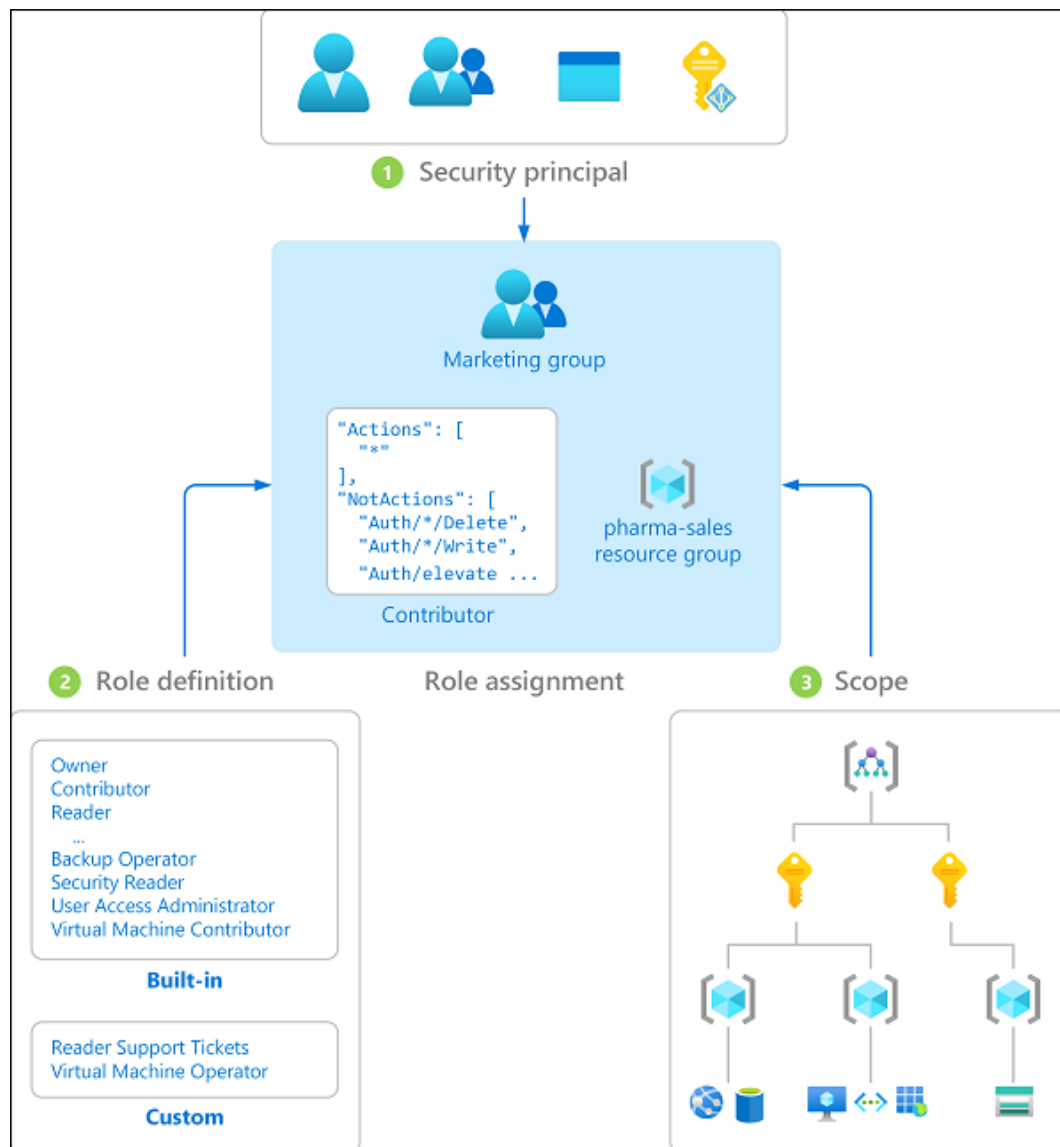


Figura 3.3 Modelul RBAC (Sursa Microsoft RBAC Overview)

In practica, acest model este implementat prin utilizarea **grupurilor de securitate** din Active Directory. Resursele retelei, cum ar fi directoarele partajate de date, primesc permisiuni de citire sau scriere asociate unui grup specific, nu unor indivizi. Cand un nou angajat este integrat in departamentul de IT, contul acestuia este adaugat in grupul de securitate aferent. Automat, prin mostenirea politicilor RBAC, angajatul primeste acces la resursele

departamentului sau si este restrictionat complet de la accesarea datelor din alte departamente, cum ar fi cel de Resurse Umane sau Financiar.

Implementarea RBAC prin scripting si automatizare reduce semnificativ riscul erorilor umane, previne fenomenul de acumulare a privilegiilor (cand un angajat isi pastreaza vechile drepturi de acces dupa ce isi schimba departamentul) si faciliteaza auditurile de conformitate, demonstrand clar cine are acces la ce informatii si mai ales din ce motiv de business.

## **Aplicabilitate Practica – Proiectul “AllSafe”**

A doua parte a lucrării detaliaza implementarea tehnica a conceptelor teoretice discutate anterior. Obiectivul principal al proiectului practic a fost construirea unui mediu de **retea corporativ** functional, denumit fictiv **“AllSafeCorp”** si securizarea acestuia utilizand principiile de *Zero Trust*, *Modelul de Tiering* si *automatizarea infrastructurii prin cod*. Mediul creat simuleaza provocarile reale dintr-o companie si demonstreaza eficacitatea politicilor de restrictionare a accesului in prevenirea miscarii laterale a unui potential atacator.

## **Proiectarea Arhitecturii si Infrastructura ca Cod (IaC)**

- ***Definirea mediului de laborator si a topologiei de retea.***

Pentru a reflecta cu acuratete arhitectura unei retele moderne de tip intreprindere, laboratorul a fost construit intr-un mediu complet virtualizat, permitand izolarea retelei si testarea in siguranta a politicilor de securitate. Topologia de baza este alcatuita din doua componente principale care comunica printr-un switch virtual inter. Prima componenta este **Controlerul de Domeniu (Domain Controller)**, responsabil pentru gestionarea identitatilor si a politicilor de securitate pentru domeniul local *“allsafecyber.local”*.

*Alegerea platformei de virtualizare a fost dictata de necesitatea unei solutii care sa ofere performanta ridicata, stabilitate si posibilitatea de a gestiona resursele hardware in mod granular. Astfel, pentru acest proiect a fost utilizat*

hipervizorul **KVM (Kernel-based Virtual Machine)**, o solutie de virtualizare de tip “*bare-metal*” sau *hibrida*, integrata direct in nucleul **Linux**. KVM permite transformarea sistemului gazda intr-un hipervizor de tip 1, oferind masinilor virtuale acces direct la instructiunile procesorului prin extensiile de virtualizare hardware.

Pentru emularea hardware-ului si facilitarea executiei codului, KVM lucreaza in tandem cu **QEMU (Quick Emulator)**. In timp ce KVM se ocupa de accelerarea procesorului si a memorie, QEMU emuleaza restul componentelor necesare, cum ar fi *placile de retea, controllere de disc si interfetele grafice*. Aceasta combinatie asigura un echilibru optim intre viteza nativa de executie si flexibilitatea emularii.

Gestionarea acestui ecosistem complex a fost realizata prin intermediul **virt-manager (Virtual Machine Manager)**. Aceasta este o aplicatie de management bazata pe interfata grafica si CLI, care utilizeaza biblioteca libvirt pentru a controla ciclul de viata al masinilor virtuale. Utilizarea virt-manager a permis configurarea retelelor virtuale izolate, asigurand o stare de revenire sigura in cazul unor configurari eronate in timpul procesului de hardening al Active Directory.

```
#Instalarea componentelor de virtualizare pe sistemul gazda  
sudo pacman -Syu  
sudo pacman -S qemu-kvm libvirt-daemon-system libvirt-clients virt-  
manager bridge-utils
```

O decizie arhitecturala importanta in proiectarea acestui laborator a fost implementarea DC-ului pe un sistem de operare de tip **Server Core**. Prin eliminarea interfetei grafice, versiune Server Core reduce dramatic amprenta de memorie, dar, mult mai important din perspectiva securitatii cibernetice, reduce semnificativ suprafata de atac. Fara *aplicatii grafice, browsere web sau instrumente suplimentare instalate pe server*, numarul de **vulnerabilitati potentiale** scade exponential.

A doua componenta a laboratorului este o statie de lucru client care ruleaza sistemul de operare **Windows 10**. Aceasta masina reprezinta nivelul



utilizatorilor finali (Tier 2) si actioneaza ca punctul principal de testare a politicilor de izolare si a restrictiilor aplicate conturilor cu drepturi depline.

Un element esential in replicarea fidela a unei infrastructuri corporative a fost configurarea segmentelor de retea prin intermediul **retelei virtuale (Virtual Networking)** in libvirt. Pentru a simula prezenta unui **firewall hardware** si pentru a asigura izolarea mediului de test, masinile virtuale au fost configurate cu doua interfete de retea distincte, implementand astfel conceptul de retea de tip **“Dual-Homed”**.

Prima interfata este conectata la un switch virtual de tip **NAT (Network Address Translation)**. Aceasta indeplineste rolul de interfata de management, permitand descarcarea actualizarilor de securitate si modulelor PowerShell necesare pe Controlerul de Domeniu, simuland totodata conexiunea catre **“Lumea Exterioara” (WAN)**.

Cea de a doua interfata este atasata unei retele virtuale de tip **Isolated**. Acest segment de retea nu are acces direct la internet si reprezinta **“Intranetul”** securizat al AllSafeCorp. Prin aceasta configurare, tot traficul de autentificare Kerberos si replicarea politicilor GPO intre **“DC1”** si **“ALDERSON-PC”** se desfasoara intr-un mediu complet controlat si protejat de interceptari externe. Aceasta separara la nivel de hardware virtual constitue prima bariera de aparare, asigurandu-se ca nicio miscare laterala nu poate evada din laborator catre sistemul gazda sau catre reteaua fizica.

```
Administrator: C:\Windows\system32\cmd.exe
PS C:\Users\Administrator> Get-NetAdapter

Name      InterfaceDescription      ifIndex Status      MacAddress      LinkSpeed
-----
Ethernet  Red Hat VirtIO Ethernet Adapter      6 Up      52-54-00-48-EF-C2      10 Gbps
Ethernet 2 Red Hat VirtIO Ethernet Adapter #2    10 Up      52-54-00-48-79-08      10 Gbps

PS C:\Users\Administrator>
```

```
Administrator: C:\Windows\system32\cmd.exe
PS C:\Users\Administrator> Get-NetAdapter

Name      InterfaceDescription      ifIndex Status      MacAddress      LinkSpeed
-----
Ethernet  Red Hat VirtIO Ethernet Adapter      7 Up      52-54-00-48-EF-C2      10 Gbps
Ethernet 2 Red Hat VirtIO Ethernet Adapter #2    6 Up      52-54-00-48-79-08      10 Gbps

PS C:\Users\Administrator> Get-DnsClient -InterfaceIndex 6

InterfaceAlias      Interface      ConnectionSpecificSuffix      ConnectionSpecificSuffix      RegisterThisConn      UseSuffixWhen
-----
Ethernet 2          6              {}                             {}                             True                  False

PS C:\Users\Administrator> Get-DnsClient -InterfaceIndex 7

InterfaceAlias      Interface      ConnectionSpecificSuffix      ConnectionSpecificSuffix      RegisterThisConn      UseSuffixWhen
-----
Ethernet            7              {}                             {}                             True                  False

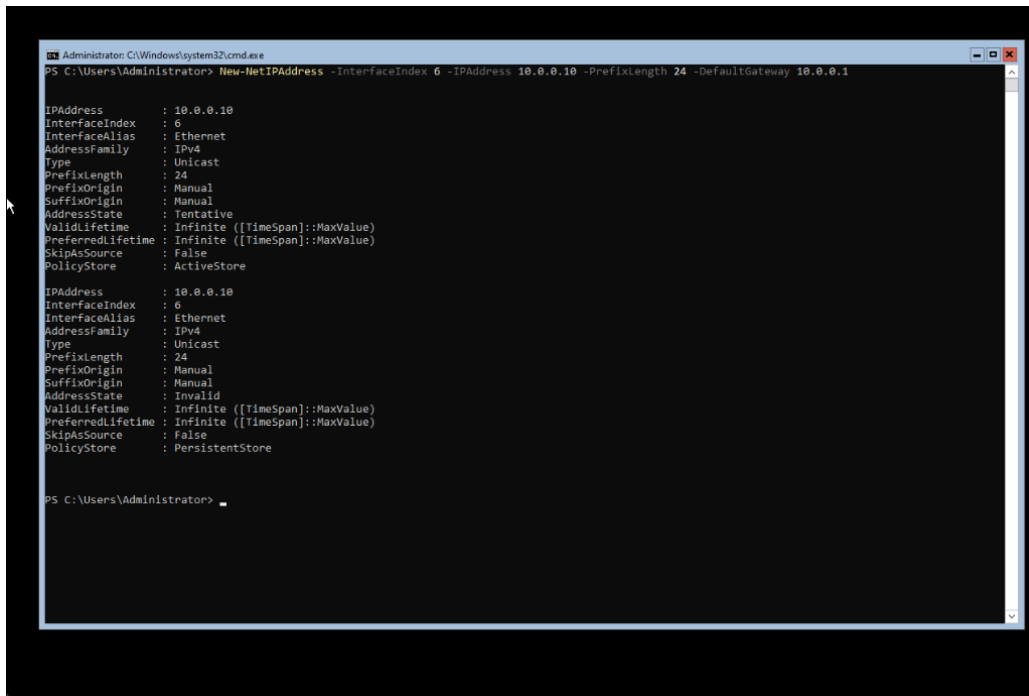
PS C:\Users\Administrator> Get-DnsClientServerAddress -InterfaceIndex 7

InterfaceAlias      Interface      Address      ServerAddresses
-----
Ethernet            7 IPv4      {8.8.8.8}
Ethernet            7 IPv6      {}

PS C:\Users\Administrator> Get-DnsClientServerAddress -InterfaceIndex 6

InterfaceAlias      Interface      Address      ServerAddresses
-----
Ethernet 2          6 IPv4      {}
Ethernet 2          6 IPv6      {fec0:0:0:ffff::1, fec0:0:0:ffff::2, fec0:0:0:ffff::3}

PS C:\Users\Administrator>
```



```
Administrator: C:\Windows\system32\cmd.exe
PS C:\Users\Administrator> New-NetIPAddress -InterfaceIndex 6 -IPAddress 10.0.0.10 -PrefixLength 24 -DefaultGateway 10.0.0.1

IPAddress      : 10.0.0.10
InterfaceIndex  : 6
InterfaceAlias  : Ethernet
AddressFamily   : IPv4
Type            : Unicast
PrefixLength    : 24
PrefixOrigin    : Manual
SuffixOrigin    : Manual
AddressState    : Tentative
ValidLifetime   : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime : Infinite ([TimeSpan]::MaxValue)
SkipAsSource    : False
PolicyStore     : ActiveStore

IPAddress      : 10.0.0.10
InterfaceIndex  : 6
InterfaceAlias  : Ethernet
AddressFamily   : IPv4
Type            : Unicast
PrefixLength    : 24
PrefixOrigin    : Manual
SuffixOrigin    : Manual
AddressState    : Invalid
ValidLifetime   : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime : Infinite ([TimeSpan]::MaxValue)
SkipAsSource    : False
PolicyStore     : PersistentStore

PS C:\Users\Administrator>
```

Figura 4.1 Configurarea interfetelor de retea pe Controlerul de Domeniu

- ***Automatizarea prin PowerShell si conceptul de Infrastructure as Code (IaC)***

Construirea manuala a unui mediu *Active Directory*, care implica navigarea prin multiple interfete grafice pentru a crea *utilizator, grupuri si politici*, este un proces predispus la **erori umane** si **dificil de replicat**. Pentru a alinia acest proiect la standardele moderne de ingineria a sistemelor, intreaga infrastructura a fost implementata folosind conceptul de **Infrastructura ca Cod (IaC)**. Toate configurarile, de la promovarea serverului la rangul de *Controler de Domeniu*, pana la crearea ierarhiei organizationale, au fost programate si executate prin intermediul scripturilor **PowerShell**.

Utilizarea PowerShell pentru orchestrarea mediului ofera garantia repetabilitatii absolute. Un script bine definit va produce exact aceeasi arhitectura de retea de fiecare data cand este rulat, eliminand inconsecventele. Mai mult, in contextul administratii unui sistem *Server Core*, cunoasterea comenzilor *PowerShell* este o necesitate absoluta. Transformarea configurarilor de securitate in linii de cod a permis

documentarea precisa a fiecarui pas logic, facilitand trasabilitatea actiunilor si oferind posibilitatea de a implementa rapid concepte complexe de securitate care, altfel, ar necesita ore de configurari manuale.

```
PS C:\Users\Administrator> Install-ADDSForest -DomainName "allsafecyber.local"
SafeModeAdministratorPassword: *****
Confirm SafeModeAdministratorPassword: *****

The target server will be configured as a domain controller and restarted when this operation is complete.
Do you want to continue with this operation?
[Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "Y"):
WARNING: Windows Server 2022 domain controllers have a default for the security setting named "Allow cryptography
algorithms compatible with Windows NT 4.0" that prevents weaker cryptography algorithms when establishing security
channel sessions.

For more information about this setting, see Knowledge Base article 942564
(http://go.microsoft.com/fwlink/?LinkId=104751).

WARNING: A delegation for this DNS server cannot be created because the authoritative parent zone cannot be found
or it does not run Windows DNS server. If you are integrating with an existing DNS infrastructure, you should
manually create a delegation to this DNS server in the parent zone to ensure reliable name resolution from outside
the domain "allsafecyber.local". Otherwise, no action is required.

WARNING: Windows Server 2022 domain controllers have a default for the security setting named "Allow cryptography
algorithms compatible with Windows NT 4.0" that prevents weaker cryptography algorithms when establishing security
channel sessions.

For more information about this setting, see Knowledge Base article 942564
(http://go.microsoft.com/fwlink/?LinkId=104751).

WARNING: A delegation for this DNS server cannot be created because the authoritative parent zone cannot be found
or it does not run Windows DNS server. If you are integrating with an existing DNS infrastructure, you should
manually create a delegation to this DNS server in the parent zone to ensure reliable name resolution from outside
the domain "allsafecyber.local". Otherwise, no action is required.

Message Context RebootRequired Status
-----
Operation completed successfully DCPromo.General.3 False Success
```

Figura 4.2 Promovarea serverului la rolul de Controler de Domeniu exclusiv prin intermediul modulelor PowerShell, respectand principiile de Infrastructura ca Cod

- **Implementarea structurii de Unitati Organizationale (OU)**

Transpunerea *Modelului de Tiering* din teorie in practica a inceput cu organizarea logica a bazei de date *Active Directory*. Pentru a asigura o segregare clara, a fost creata o structura ierarhica de *Unitati Organizationale (OU)* care reflecta exact nivelurile de incredere si departamentele companiei fictive AllSafeCorp. La baza ierarhiei a fost generat un container parinte principal, denumit "AllSafeCorp", destinat sa gazduiasca toate resursele corporative si sa aplice politicile globale de baza.

In interiorul acestui container, scripturile de automatizare au generat trei Unitati Organizationale distincte, aliniate direct la arhitectura de securitate discutata anterior. Primul OU, denumit "T0\_Infrastructure", a fost creat pentru a gazdui exclusiv Controlerul de Domeniu si conturile cu cel mai inalt grad de privilegiu, izolandu-le astfel de restul retelei. Al doilea OU, "T1\_Servers", a fost pregatit logic pentru a incapsula viitoarele servere de aplicatii si date. In cele din urma, a fost generat OU-ul "T2\_Assets", container

desemnat pentru statiile de lucru standard si calculatoarele angajatilor, reprezentand cel mai expus nivel al retelei. Aceasta segregare logica stricta a fost pasul fundamental necesar inainte de aplicarea politicii de interzicere a autentificarii interactive a administratorilor pe echipamentele din Tier 2.

## **Automatizarea Infrastructurii si Gestiunea Identitatilor**

Dupa stabilirea fundamentului de virtualizare si promovarea masinii *Server Core* la rolul de *Controler de Domeniu*, pasul critic in implementarea modelului *Zero Trust* a fost construirea bazei de date *Active Directory*. Pentru a respecta principiile moderne de inginerie a sistemelor si pentru a asigura repetabilitatea perfecta a mediului, configurarea nu a fost realizata manual, ci complet automatizat prin scripturi *PowerShell*, respectand paradigma *Infrastructurii ca Cod*.

- ***Crearea ierarhiei organizationale (OU) si a grupurilor de securitate***

Primul pas in transpunerea *Modelului de Tiering* din teorie in practica a fost generarea structurii de containere logice (Unitatile Organizationale). Scriptul de initializare a fost conceput pentru a crea un container parinte “*AllSafeCorp*”, in interiorul caruia au fost generate dinamic cele trei niveluri de izolare: “*T0\_Infrastructure*”, “*T1\_Servers*”, “*T2\_Assets*”. Aceasta ierarhie este esentiala deoarece permite aplicarea ulterioara a ***Politicilor de Grup (GPO)*** cu un grad inalt de granularitate, tinand exclusiv resursele de la un anumit nivel de incredere. De asemenea, scriptul creeaza containere operationale critice pentru securitate: “*Emergency\_Accounts*” pentru acces de urgenta complet izolat, “*Service\_Accounts*” pentru rularea serviciilor automate fara interactiune umana si “*Disabled\_Accounts*” pentru conturile compromise sau ale angajatilor care au parasit compania.

```
# Sursa de cod 5.1. Fragment din 05_BuildArchitecture.ps1
$Domain = "DC=allsafecyber,DC=local"
```

```

$ParentOU = "OU=AllSafeCorp,$Domain"
"OU=T2_Assets,$ParentOU"
# Crearea containerului principal si a nivelurilor de Tiering
New-ADOrganizationalUnit -Name "AllSafeCorp" -Path $Domain
New-ADOrganizationalUnit -Name "T0_Infrastructure" -Path
$ParentOU
New-ADOrganizationalUnit -Name "T1_Servers" -Path $ParentOU
New-ADOrganizationalUnit -Name "T2_Assets" -Path $ParentOU
# Crearea OU-urilor operationale si de securitate
New-ADOrganizationalUnit -Name "Service_Accounts" -Path
$ParentOU
New-ADOrganizationalUnit -Name "Emergency_Accounts" -Path
$ParentOU
New-ADOrganizationalUnit -Name "Disabled_Accounts" -Path
$ParentOU
# Crearea containerelor pentru Grupuri si ierarhia departamentala
New-ADOrganizationalUnit -Name "T2_Groups" -Path $AssetsOU
New-ADOrganizationalUnit -Name "HR" -Path $AssetsOU
New-ADOrganizationalUnit -Name "Users" -Path "OU=HR,$AssetsOU"
New-ADOrganizationalUnit -Name "Computers" -Path
"OU=HR,$AssetsOU"

```

La nivelul departamentelor, arhitectura devine si mai granulara, fiecare departament primind propriul sau OU, divizat intern in “*Users*” si “*Computers*”. Aceasta separare este vitala pentru aplicarea diferentiata a GPOs pe dispozitive fata de utilizatori.

```

PS C:\Users\adm_ealderson> Get-ADOrganizationalUnit -SearchBase "OU=AllSafeCorp,DC=allsafecyber,DC=local" -Filter * |
Format-Table Name, DistinguishedName -AutoSize

Name                DistinguishedName
----                -
AllSafeCorp          OU=AllSafeCorp,DC=allsafecyber,DC=local
T0_Infrastructure    OU=T0_Infrastructure,OU=AllSafeCorp,DC=allsafecyber,DC=local
T0_Groups            OU=T0_Groups,OU=T0_Infrastructure,OU=AllSafeCorp,DC=allsafecyber,DC=local
Emergency_Accounts   OU=Emergency_Accounts,OU=T0_Infrastructure,OU=AllSafeCorp,DC=allsafecyber,DC=local
T1_Servers           OU=T1_Servers,OU=AllSafeCorp,DC=allsafecyber,DC=local
T1_Groups            OU=T1_Groups,OU=T1_Servers,OU=AllSafeCorp,DC=allsafecyber,DC=local
T2_Assets            OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
T2_Groups            OU=T2_Groups,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
HR_Dept              OU=HR_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Computers            OU=Computers,OU=HR_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Users                OU=Users,OU=HR_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Red_Team             OU=Red_Team,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Computers            OU=Computers,OU=Red_Team,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Users                OU=Users,OU=Red_Team,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Blue_Team            OU=Blue_Team,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Computers            OU=Computers,OU=Blue_Team,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Users                OU=Users,OU=Blue_Team,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
IT_Dept              OU=IT_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Computers            OU=Computers,OU=IT_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Users                OU=Users,OU=IT_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Management           OU=Management,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Computers            OU=Computers,OU=Management,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Users                OU=Users,OU=Management,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Threat_Intelligence  OU=Threat_Intelligence,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Computers            OU=Computers,OU=Threat_Intelligence,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Users                OU=Users,OU=Threat_Intelligence,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local
Disabled_Users       OU=Disabled_Users,OU=AllSafeCorp,DC=allsafecyber,DC=local
Service_Accounts     OU=Service_Accounts,OU=AllSafeCorp,DC=allsafecyber,DC=local

```

Figura 5.1 Validarea executiei scriptului de infrastruttura ca cod: structura ierarhica de tip Tiering si containerele departamentale generate automat in Active Directory

Pentru a asigura o gestiune stricta a permisiunilor, in interiorul fiecarui nivel de Tiering au fost create OUs dedicate grupurilor de securitate necesare (*T0\_Groups*, *T1\_Groups*, *T2\_Groups*) pentru implementarea **Controlului Accesului pe Baza de Roluri (RBAC)**. In interiorul unitatii organizationale *T2\_Groups* au fost create grupurile de securitate bazate pe departamente, precum *IT\_Users*, *HR\_Users*. Aceste grupuri reprezinta puntea de legatura intre identitatea viitorilor angajati si resursele la care acestia vor avea acces, decupland complet permisiunile de conturi individuale.

- **Aprovizionarea automata a utilizatorilor din surse externe**

Urmatoarea etapa a constat in popularea structurii create cu identitati operationale. Intr-un mediu corporativ real, departamentul de Resurse Umane genereaza un fisier standardizat cu noii angajati. Pentru a simula acest flux, a fost creat un fisier de tip **CSV (Comma-Separated Values)** denumit *employees.csv*, continand date de baza: nume, prenume,

*departament, functie*. Scriptul principal de aprovizionare itereaza prin fiecare linie a acestui fisier si traduce datele brute in obiecte Active Directory. Un aspect fundamental al acestui algoritm este logica sa de rutare. Scriptul preia departamentul angajatului, genereaza un nume de utilizator standardizat si plaseaza contul direct in structura Tier 2, adaugandu-l simultan in grupul de securitate corespunzator. Astfel, interventia manuala a administratorului este complet eliminata, reducand la zero riscul alocarii incorecte a drepturilor. De asemenea este utilizat parametrul `-ChangePasswordAtLogon $true`, care este utilizat ca o masura de securitate critica, asigurand ca administratorul care ruleaza scriptul nu va cunoaste niciodata parola finala a utilizatorului.

```
# Sursa de cod 5.2. Fragment din 07_AutomaticUserCreation.ps1
# Importul datelor sursa din fisierul CSV
$users = Import-Csv -Path "C:\Setup\employees.csv"
foreach ($user in $users) {
    $samAccountName = ($user.FirstName.Substring(0,1) +
    $user.LastName).ToLower()
    $TargetOU="OU=Users,OU=$(($user.Department)_Dept,OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local"
    New_ADUser -SamAccountName $samAccountName -UserPrincipalName
    "$samAccountName@allsafecyber.local" -Name "$($user.FirstName)
    $($user.LastName)" -GivenName $user.FirstName -Surname
    $user.LastName -Department $user.Department -Title $user.Title -
    Path $TargetOU -AccountPassword (ConvertTo-SecureString
    "AllSafe2026!" -AsPlainText -Force) -Enabled $true -
    ChangePasswordAtLogon $true
    $GroupName = if ($user.Department -eq "IT") { "IT_Users" } else
    { "HR_Users" }
    Add-ADGroupMember -Identity $GroupName -Members $samAccountName
}
```



```
PS C:\Users\adm_ealderson\Desktop> Get-ADUser -Filter * -SearchBase "OU=T2_Assets,OU=AllSafeCorp,DC=allsafecyber,DC=local" | Select-Object Name, SamAccountName, Enabled | Format-Table -AutoSize
```

| Name             | SamAccountName | Enabled |
|------------------|----------------|---------|
| Angela Moss      | amoss          | True    |
| Tyrell Wellick   | twellick       | True    |
| Trenton Al-Fayed | tal-fayed      | True    |
| Mobley Eshmail   | meshmail       | True    |
| Dom DiPierro     | ddipierro      | True    |
| Lloyd Chung      | lchung         | True    |
| Ollie Parker     | oparker        | True    |
| Gideon Goddard   | ggoddard       | True    |
| Susan Jacobs     | sjacobs        | True    |

Figura 5.2 Utilizatorii importati si rutati dinamic in sub-containerele specifice departamentelor lor, validat in interfata Active Directory Users si Computers

- **Implementarea izolarii datelor la nivel de sistem de fisiere (NTFS)**

Ultima faza a automatizarii infrastructurii a fost demonstrarea eficacitatii grupurilor de securitate (RBAC) prin aplicarea lor pe directoarele partajate de retea. Simpla creare a utilizatorilor nu asigura securitatea datelor daca mecanismele sistemului de operare nu sunt configurate pentru a respinge accesul neautorizat.

# Sursa de cod 5.3. Fragment din 08\_FileSharing.ps1

```
$BaseSharePath = "C:\Shares"  
$DomainNetBIOS = "ALLSAFECYBER"  
$Departments = @(  
@{ Name="HR_Data"; Group="HR_Users" },  
@{ Name="IT_Data"; Group="IT_Users" },  
@{ Name="Red_Team_Data"; Group="Red_Team_Users" },  
@{ Name="Blue_Team_Data"; Group="Blue_Team_Users" },  
@{ Name="Management_Data"; Group="Management_Users" },  
@{ Name="Threat_Intel_Data"; Group="Threat_Intelligence_Users" }  
)  
foreach ($Dept in $Departments) {  
$FolderPath = Join-Path -Path $BaseSharePath -ChildPath  
$Dept.Name  
$TargetGroup = "$DomainNetBIOS\$($Dept.Group)"
```

```
New-Item -Path $FolderPath -ItemType Directory -Force | Out-Null
New-SmbShare -Name $Dept.Name -Path $FolderPath -FullAccess
"Everyone"
$Acl = Get-Acl $FolderPath
$Acl.SetAccessRuleProtection($true, $false)
$Rule = New-Object
System.Security.AccessControl.FileSystemAccessRule($TargetGroup,
"Modify", "ContainerInherit,ObjectInherit", "None", "Allow")
$Acl.AddAccessRule($Rule)
Set-Acl $FolderPath $Acl
```

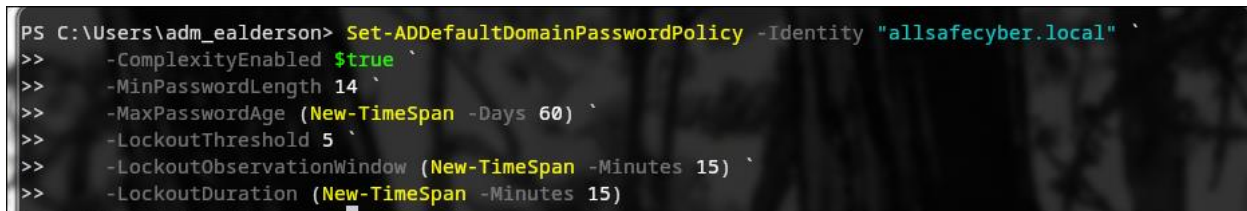
Scriptul a generat directoare fizice pentru fiecare departament si a modifica **Listele de Control al Accesului (ACL – Access Control Lists)** direct la nivel de disc (**NTSF**). Pasul cristic de securitate implementat in cod a fost dezactivarea mostenirii permisiunilor. Implicit, in Windows, orice folder nou creat mosteneste permisiuni permissive de la partitia parinte. Prin ruperea acestei mosteniri si aplicarea unei politici stricte de atribuire exclusiva, sistemul adopta o postura “*Deny by Default*”, aliniindu-se perfect cerintelor Zero Trust.

Desi *partajarea in retea (SMB)* este tehnic vizibila, permisiunile NTFS actioneaza ca un filtru definitiv. Daca un utilizator care nu apartine grupului desemnat incearca sa acceseze folderul, nucleul sistemului de operare ii va bloca interactiunea, prevenind astfel furtul de date inter-departamental.

## **Securizare Avansata (Hardening), Validare si Testare**

O arhitectura bine structurata la nivel de directoare si grupuri (Tiering si RBAC) reprezinta doar fundatia securitatii. Fara aplicarea unor restrictii stricte la nivel de sistem de operare si politici de domeniu, atacatorii pot exploata configuratiile implicite permissive ale Windows-ului. In aceasta etapa a proiectului, securitatea a fost intarita proactiv (*Hardening*) prin intermediul *Politicilor de Grup (GPO)*, limitand sever miscarea laterala si vizibilitatea atacatorilor in retea.

- **Securizarea Globala a Identitatilor si Auditarea (T0)**



```
PS C:\Users\adm_ealderson> Set-ADDefaultDomainPasswordPolicy -Identity "allsafecyber.local" `
>> -ComplexityEnabled $true `
>> -MinPasswordLength 14 `
>> -MaxPasswordAge (New-TimeSpan -Days 60) `
>> -LockoutThreshold 5 `
>> -LockoutObservationWindow (New-TimeSpan -Minutes 15) `
>> -LockoutDuration (New-TimeSpan -Minutes 15)
```

Figura 6.1 Validarea aplicarii Politcii de Grup (GPO) pentru securizarea globala a identitatilor, impunand limite stricte de complexitate si lungime a parolelor.

Primul pas in faza de hardening a vizat politicile de baza ale domeniului, aplicate la nivelul radacinii Active Directory pentru a garanta ca nicio identitate nu poate fi creata cu credentiale slabe. Scriptul de securizare globala a automatizat impunerea unor cerinte stricte de complexitate a parolelor si lungime minima.

In paralel cu intarirea identitatilor, a fost implementat un sistem de vizibilitate prin auditare. Securitatea cibernetica moderna opereaza sub premisa “*presupunerea compromiterii*”, ceea ce face ca logarea evenimentelor sa fie critica pentru detectie. Prin intermediul scriptului **New-T0AuditVaultGPO.ps1**, a fost configurata o politica de auditare avansata care integreaza succesul si esecul proceselor vitale. Un element central al acestei politici este activarea *Event ID 4688 (Process Creation)* combinata cu logarea liniilor de comanda. Aceasta configuratie permite echipei de securitate sa vada nu doar ce proces a fost lansat, ci si parametrii exacti executati de un potential atacator, neutralizand astfel tehnicile de obfuscare folosite in atacurile de tip *Living off the Land (LotL)*.

- **Complexitatea implementarii izolarii privilegiilor si limitari tehnice**

O componenta fundamentala a modelului Zero Trust aplicat in Active Directory este prevenirea miscarii laterale prin interzicerea autentificarii administratorilor de domeniu (Tier 0) pe statiile de lucru standard (Tier 2). In teorie, acest mecanism se aplica prin Politici de Grup GPO care configureaza

secțiunea *User Rights Assignment*, specific impunând regulile “*Deny log on locally*” și “*Deny access to this computer from the network*” pentru grupurile cu privilegii ridicate.

În cadrul testelor de laborator, automatizarea completă a acestei izolări prin scripturi PowerShell a relevat provocări tehnice semnificative. Arhitectura sistemului de operare Windows tratează drepturile de autentificare mult mai strict decât setările standard de sistem. Spre deosebire de restricțiile aplicațiilor care pot fi impuse prin modificarea directă a regiștrilor sistemului (**RegEdit**), permisiunile de autentificare sunt protejate și stocate într-o bază de date locală de securitate securizată (**secedit.sdb**).

Încercările de a automatiza aceste restricții exclusiv prin scripturi PowerShell standard s-au lovit de lipsa unor module native care să interacționeze direct și sigur cu **Autoritatea Locală de Securitate (LSA – Local Security Authority)**. De asemenea, testele care au implicat modificarea forțată a cheilor de registru asociate politicilor au demonstrat că sistemul de operare ignoră aceste suprascrieri pentru a menține integritatea bazei de date.

Acest comportament al sistemului subliniază o limitare importantă în implementarea conceptului de Infrastructure as Code în mediile Windows atunci când se manipulează baza de date LSA. Concluzia acestei etape este că, pentru setările critice de tip *User Right Assignment*, dependența exclusivă de scripturi prezintă riscuri de neaplicare a politicilor în mediile de producție reale, izolarea nivelului Tier 0 necesită fie utilizarea interfeței grafice pentru generarea garantată a template-ului de securitate, fie utilizarea unor utilități de orchestrare de nivel inferior. Această experiență practică confirmă faptul că securitatea robustă necesită validare manuală constantă, evidențiind diferența dintre teoria arhitecturală și implementarea tehnică la nivel de nucleu (OS).

- ***Reducerea Suprafetei de Atac pe Stările de Lucru (T2 Baseline & Restrictions)***

În arhitectura Zero Trust și în Modelul de Tiering, stațiile de lucru din nivelul Tier 2 reprezintă cel mai vulnerabil punct al rețelei, fiind expuse direct atacurilor de tip *Phishing* și *inginerie socială*. Odată ce un atacator compromite o stație, primul său obiectiv este să utilizeze instrumentele native ale sistemului de operare pentru a executa cod malicios și a obține persistență, tactica cunoscută sub numele de *Living off the Land*.

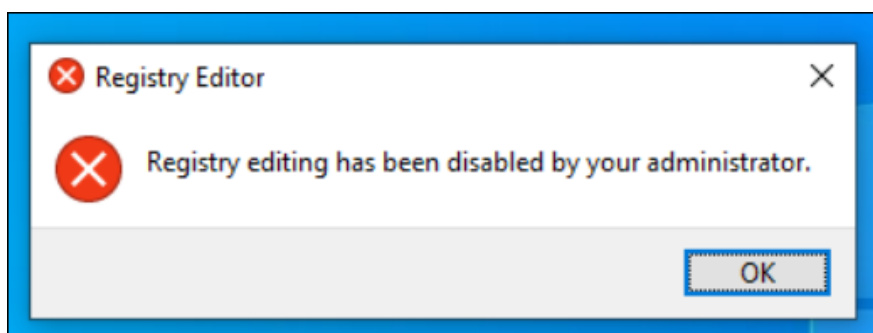
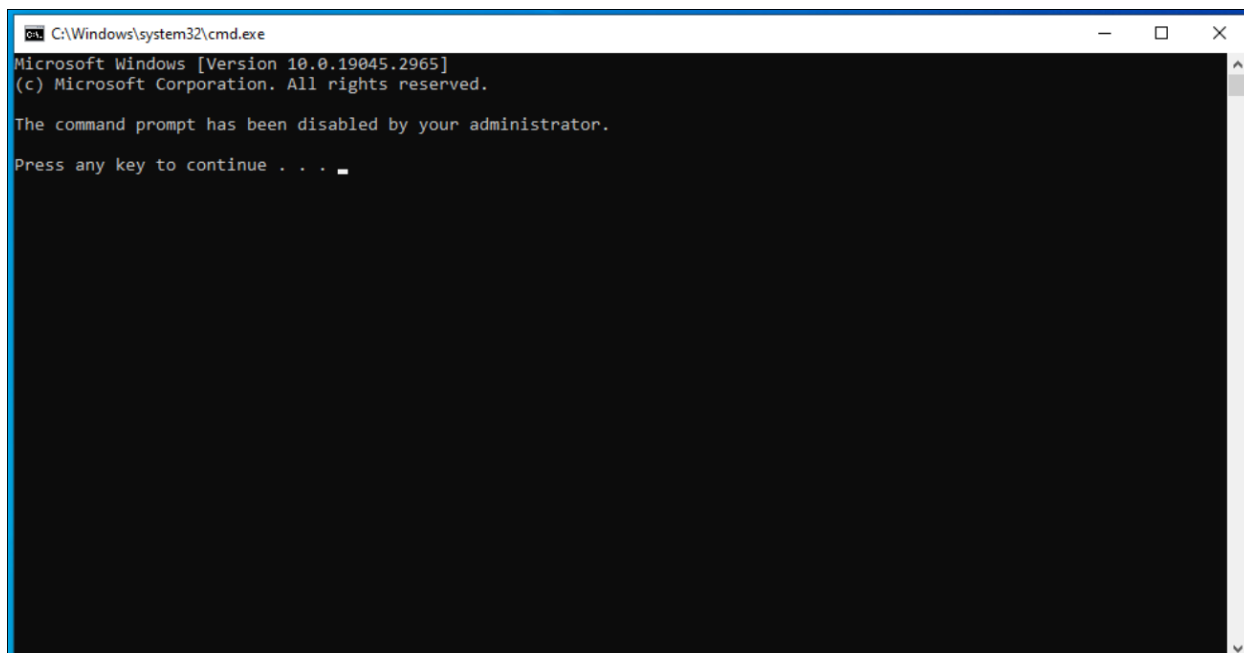
Pentru a contracara aceste tehnici, a fost implementată o politică de securitate strictă, "*T2\_Baseline & Restrictions*", distribuită automat prin GPO către toate calculatoarele din containerele departamentale. Această politică aplică principiul privilegiului minim la nivel de aplicație: utilizatorii standard, care folosesc mașinile exclusiv pentru sarcini de birou, nu au nicio justificare operațională pentru a accesa unelte de administrare. Astfel, prin scriptul *New-T2RestrictionsGPO.ps1*, s-a configurat dezactivarea completă a interfețelor de linie de comandă (*Command Prompt*), restricționarea execuției modulelor *PowerShell* și blocarea accesului la *Editorul de Registru* (*regedit.exe*).

- ***Validarea politicilor Zero Trust***

Pentru a demonstra eficacitatea măsurilor de întărire a securității (*Hardening*) și a politicilor de *Control al Accesului pe Bază de Roluri (RBAC)*, au fost simulate două scenarii majore de testare din perspectiva unui utilizator compromis sau rău intențional aflat la nivelul cu cele mai puține privilegii.

## **Scenariul A : Prevenirea Execuției și a Tehnicilor LotL**

În acest scenariu, se presupune că o stație de lucru a fost infectată cu un malware de tip *Dropper* sau că un utilizator încearcă intenționat să ruleze comenzi de recunoaștere a rețelei. Testele au arătat că tentativele de a lansa *Command Prompt* sau *Editorul de Registru* sunt interceptate și blocate direct de nucleul sistemului de operare, informând utilizatorul că acțiunea a fost anulată din cauza restricțiilor impuse de administrator.



De asemenea, restrictionarea mediului PowerShell previne rularea scripturilor malitioase de tip Fileless Malware descarcate din memorie.

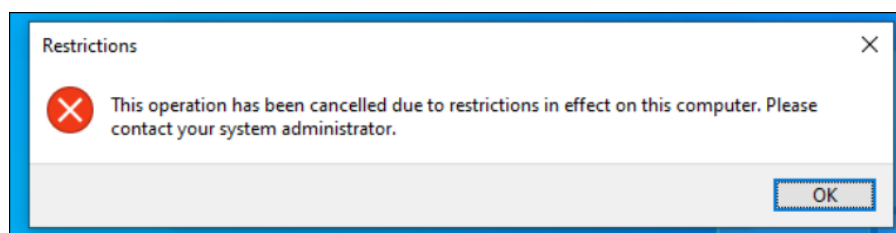


Figura 6.5 Validarea restrictiilor aplicate mediului PowerShell pentru utilizatorii non-administrativi

## Scenariul B: Izolarea Datelor si Eficacitatea RBAC

Al doilea scenariu valideaza segregarea datelor inter-departamentale. Utilizand contrul unui angajat care apartine exclusiv departamentului IT, s-a incercat accesarea directoarelor partajate apartinand departamentului de Resurse Umane (HR). Desi calea de retea poate fi tehnic interogata, ruperea mostenirii permisiunilor NTFS si aplicarea politicilor de *Deny by Default* isi dovedesc eficienta: sistemul returneaza o eroare de tip **“Access Denied”**.

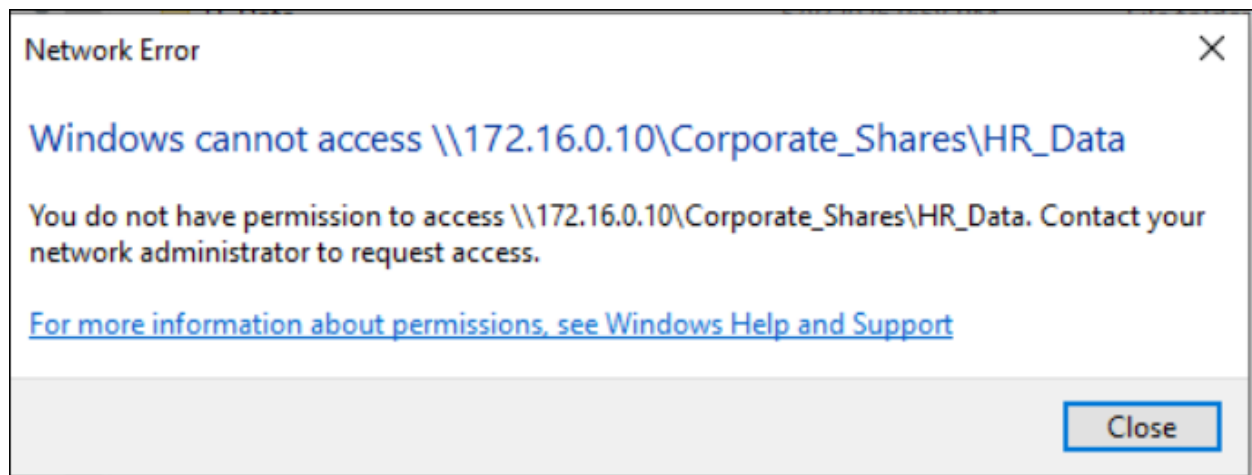


Figura 6.6 Validarea aplicarii RBAC: interzicerea criptografica a accesului la datele sensibile pentru utilizatorii neautorizati, blocand astfel furtul de informatii si extorcarea

Rezultatele acestor teste practice confirma ca implementarea conceptelor Zero Trust si a Infrastructurii ca Cod a generat un mediu de retea rezilient, capabil sa limiteze daunele chiar si in cazul compromiterii perimetrului initial.

## **Concluzii**

Aceasta lucrare a analizat tranzitia critica a securitatii cibernetice de la modelul perimetral traditional la arhitectura moderna *Zero Trust*, concentrandu-se pe securizarea infrastructurilor bazate pe *Microsoft Active Directory Domain Services*. Obiectivul principal al tezei a fost demonstrarea faptului ca intr-un mediu corporativ descentralizat, identitatea a devenit noul perimetru de securitate, iar protejarea acesteia impune implementarea riguroasa a *principiului privilegiului minim si a izolarii administrative*.

In cadrul partii practice, a fost proiectat si construit un mediu corporativ simulat, *“AllSafeCorp”*, utilizand platforma de virtualizare **KVM/QEMU** pentru a asigura izolarea la nivel de retea. Inovatia abordarii a

constat in adoptarea paradigmei **infrastructurii ca cod**. Mediul a fost populat si configurat prin intermediul scripturilor **PowerShell**, eliminand interventia manuala si eroarea umana. Aprovizionarea automata a utilizatorilor si **aplicarea controlului accesului pe baza de roluri** direct la nivelul sistemului de fisiere au demonstrat eficienta decuplarii identitatii de resura.

Testele de validare si scenariile de securitate au confirmat succesul masurilor de intarire a sistemului. Prin intermediul *politicilor de grup*, aplicate ierarhic pe niveluri de incredere, s-a reusit blocarea proactiva a tacticilor de tip *living off the land*. Restrictionarea accesului utilizatorilor standard la interfetele de comanda si la editorul de registru a redus drastic suprafata de atac disponibila in cazul unei compromiteri initiale la nivelul Tier 2.

Cu toate acestea, Procesul de implementare a evidentiat si anumite limitari tehnice ale automatizarii. Tentativa de a impune restrictii critice de tip *user rights assignment* exclusiv prin powershell s-a lovit de protectia inerenta a bazei de date a *autoritatii locale de securitate*. Aceasta descoperire subliniaza concluzia ca automatizarea nu poate inlocui complet validarea manuala a securitatii si ca politicile nucleului sistemului de operare necesita instrumente de orchestrare specializate.

Proiectul reprezinta o fundatie solida care poate fi extinsa in cercetari viitoare. Implementarea poate fi imbunatatita prin adaugarea solutiei **Microsoft LAPS (Local Administrator Password Solution)** pentru a gestiona securizat conturile locale si prin integrarea unui sistem **SIEM (Security Information and Event Management)** pentru ingestia si corelarea log-urilor de auditare generate de **GPO-uri** implementate in nivelul Tier 0. De asemenea, o tranzitie catre un model de identitate hibrida, prin integrarea cu **Microsoft Entra ID** si implementarea **Multi-Factor Authentication (MFA)**, ar reprezenta pasul final catre alinierea completa la o arhitectura *Zero Trust cloud-native*.



## **Bibliografie**

1. Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture (NIST Special Publication 800-207)*. National Institute of Standards and Technology.
2. Microsoft. (2023). *Enterprise Access Model*. Microsoft Security Documentation. Disponibil la: <https://learn.microsoft.com/en-us/security/compass/enterprise-access-model>
3. Microsoft. (2023). *Securing Active Directory Domain Services*. Microsoft Learn.
4. Microsoft. (2022). *Role-based access control (RBAC) overview*. Microsoft Entra Documentation.
5. Metcalf, S. (2015). *Attacking Active Directory: Kerberos, Golden Tickets, and Pass-The-Hash*. ADSecurity.org.
6. Center for Internet Security (CIS). (2023). *CIS Microsoft Windows Server Benchmarks*. CISecurity.
7. MITRE Corporation. (2023). *ATT&CK Framework: Valid Accounts and Lateral Movement*. MITRE ATT&CK. Disponibil la: <https://attack.mitre.org/>
8. Payette, P., & Jones, D. (2021). *Learn PowerShell in a Month of Lunches (4th Edition)*. Manning Publications. (Pentru fundamentarea metodelor IaC utilizate în scripturi).
9. Gibson, D. (2021). *Managing Risk and Information Security: Protect to Enable*. Apress.
10. KVM Project. (2023). *Kernel Based Virtual Machine Documentation*. Disponibil la: <https://www.linux-kvm.org/>